

PLAN DE PRUEBAS

Sistema de Gestión Atlas

Informe de seguridad y calidad en el desarrollo de software

Evaluación Parcial N°1 · Caso semestral, Forma A

ISY1102 · Seguridad y Calidad en el Desarrollo de Software

Sección 004V · Escuela de Informática y Telecomunicaciones

Integrantes

Elías Delgado Manríquez

Rolando Aldana

Carrera: Ingeniería en Informática

Docente: Johnnathan René Cubillos Flores

Fecha: 15 de septiembre de 2026

ÍNDICE

1. Introducción.....	3
1.1 Contexto del software.....	3
1.2 Clasificación del producto.....	3
1.3 Propósito y alcance.....	3
2. Criterios de calidad.....	4
2.1 Calidad del producto.....	4
2.2 Seguridad.....	5
2.3 Normativas.....	5
2.4 Observaciones a la ERS.....	6
3. Plan de pruebas.....	6
3.1 Estrategia de pruebas.....	6
3.2 Tipos de prueba.....	8
3.3 Criterios de aceptación.....	8
3.4 Herramientas utilizadas.....	9
3.5 Recursos y cronograma.....	10
4. Diseño de casos de prueba.....	11
5. Cobertura y coherencia.....	17
5.1 Cobertura de requerimientos.....	17
5.2 Coherencia del plan.....	18
5.3 Brechas para la iteración 2.....	18
6. Conclusión.....	18
Referencias.....	19
Anexo A. Matriz de trazabilidad.....	20

1. Introducción

1.1 Contexto del software

Atlas es una plataforma web que CreaLab SpA desarrolla para pequeñas y medianas empresas chilenas. Permite registrar clientes, asociarles contratos con sus documentos y controlar qué usuarios de cada empresa pueden ver o modificar esa información. La Especificación de Requerimientos de Software (ERS) en su versión 1.1 define dos roles internos, administrador y editor, y exige un registro de auditoría para las acciones críticas.

La arquitectura es de tres capas: una aplicación de página única (SPA) en React 19 que consume una interfaz de programación de aplicaciones (API) REST construida en Node.js con Express 4, sobre una base de datos PostgreSQL. La sesión se maneja con JSON Web Token (JWT) de corta duración más un token de refresco, las contraseñas se almacenan con bcrypt y todo el tráfico viaja sobre Transport Layer Security (TLS). El sistema debe funcionar en computador, tablet y celular, con atención especial a usuarios adultos mayores.

1.2 Clasificación del producto

Clasificamos Atlas según los tres ejes de la asignatura para decidir dónde concentrar el esfuerzo de prueba:

Eje	Clasificación	Fundamento en la ERS
Calidad	Sistema transaccional de gestión, criticidad media-alta	Operaciones de alta, consulta, modificación y baja (CRUD) sobre clientes y contratos, tiempos de respuesta definidos (NFR-PERF) y disponibilidad de 99,5 % (NFR-DIS-1)
Seguridad	Sistema multiempresa con datos personales y bancarios	Datos bancarios de clientes (2.2), control de acceso por rol (NFR-SEG-4) y cifrado en reposo (NFR-SEG-3)
Cumplimiento	Responsable del tratamiento de datos de terceros bajo ley chilena	NFR-SEG-8, auditoría (RF-6) y acceso restringido por empresa (RB-2)

Tabla 1. Clasificación de Atlas según calidad, seguridad y cumplimiento.

Un defecto de autorización en Atlas no es solo una falla funcional: expone datos personales de terceros e incumple la normativa de protección de datos. Esa condición ordena las prioridades de todo el plan.

1.3 Propósito y alcance

El plan define cómo se verificará que Atlas cumple lo especificado antes de pasar a producción. Los objetivos son comprobar que las funciones esenciales respondan según la ERS, que ninguna empresa acceda a datos de otra, que el rol editor no pueda escribir, que los

datos personales y bancarios estén protegidos en tránsito y en reposo, que se cumplan los umbrales de rendimiento y usabilidad, y que quede evidencia suficiente para demostrar cumplimiento de la Ley 19.628 y la Ley 21.719.

El alcance cubre los requerimientos funcionales RF-1 a RF-6, las reglas de negocio RB-1 a RB-5 y los requerimientos no funcionales de seguridad, rendimiento, usabilidad, disponibilidad y compatibilidad descritos en la sección 3 de la ERS. Quedan fuera la infraestructura del proveedor de hosting, el funcionamiento interno del servicio de correo, del que solo se prueba la integración, y la auditoría legal formal, que corresponde a un asesor jurídico.

2. Criterios de calidad

Cada criterio de este capítulo se amarra a un requerimiento de la ERS y a una norma, de modo que después pueda verificarse con una prueba concreta.

2.1 Calidad del producto

Tomamos como referencia el modelo de calidad de producto ISO/IEC 25010 y nos concentramos en las características para las que la ERS define un umbral verificable.

Característica	Criterio aplicado a Atlas	Requerimiento	Métrica
Adecuación funcional	CRUD, estados de contrato y roles operan correctamente	RF-1 a RF-6	Casos funcionales aprobados
Eficiencia de desempeño	Respuesta acotada bajo carga normal	NFR-PERF-1 a 3	p95 < 300 ms, carga < 2 s, 200 usuarios
Usabilidad	Pantallas legibles y flujos claros para adultos mayores	NFR-USAB-1 a 4	SUS ≥ 70, sin bloqueos
Confiabilidad	Disponibilidad y recuperación ante fallos	NFR-DIS-1, NFR-SEG-7	Uptime ≥ 99,5 %, respaldo restaurable
Compatibilidad	Operación en los navegadores exigidos	NFR-COMPAT-1 y 2	Matriz de navegadores sin defectos bloqueantes
Mantenibilidad	Cambios y migraciones sin romper lo existente	NFR-DIS-2	Regresión automatizada por integración

Tabla 2. Criterios de calidad del producto según ISO/IEC 25010.

La seguridad, que también integra el modelo, se desarrolla en 2.2 por su peso en este proyecto. La portabilidad se aborda con menor profundidad porque la ERS no fija métricas más allá del diseño responsivo.

2.2 Seguridad

Los criterios se apoyan en OWASP Top 10 (2021) y en el nivel 2 del Application Security Verification Standard (ASVS) de OWASP, recomendado para aplicaciones que tratan datos personales.

- **Protección de datos:** TLS en todas las comunicaciones y cifrado de los datos bancarios en reposo (NFR-SEG-1, NFR-SEG-3).
- **Control de acceso:** la autorización se resuelve en el backend según rol y empresa del usuario, no ocultando controles en la interfaz (NFR-SEG-4, RB-2, RB-4).
- **Autenticación y sesión:** contraseñas con bcrypt, política de 12 caracteres con complejidad y JWT de corta vigencia que se invalida al cerrar sesión (RF-1, NFR-SEG-2, NFR-SEG-9).
- **Validación de entradas:** saneamiento contra inyección SQL (SQLi), Cross-Site Scripting (XSS) y Cross-Site Request Forgery (CSRF), con consultas parametrizadas (NFR-SEG-5).
- **Trazabilidad:** registro de auditoría de las acciones críticas, sin datos sensibles en los registros (RF-6.1, NFR-SEG-6).
- **Manejo de errores:** mensajes comprensibles para el usuario, sin trazas de pila ni detalles de la base de datos (NFR-USAB-3).

2.3 Normativas

Norma	Aplicación a Atlas
Ley 19.628, protección de la vida privada	El sistema almacena nombres, contactos, Rol Único Tributario (RUT) y datos bancarios de clientes
Ley 21.719, protección de datos personales (vigencia prevista para diciembre de 2026)	Exige seguridad, proporcionalidad y responsabilidad proactiva: hay que poder demostrar las medidas adoptadas
Ley 21.663, marco de ciberseguridad	Referencia de seguridad desde el diseño y de gestión de incidentes
Ley 21.459, delitos informáticos	Obliga a impedir y registrar accesos no autorizados; el pentest se ejecuta solo con autorización escrita
Ley 17.336, propiedad intelectual	Revisión de licencias de las librerías de terceros del proyecto
ISO/IEC 25010, ISO/IEC 27001:2022, ISO/IEC/IEEE 29119	Modelo de calidad, controles de seguridad de la información y proceso de pruebas
WCAG 2.1 nivel AA	Accesibilidad web, exigible por el perfil de usuario adulto mayor

Tabla 3. Normas y estándares aplicables al proyecto.

2.4 Observaciones a la ERS

La lectura de la ERS dejó puntos ambiguos que afectan los criterios de aceptación y que conviene resolver con CreaLab. Mientras tanto, se trabajan como supuestos declarados:

1. La ERS fija una tipografía de 12 px, insuficiente para el público adulto mayor declarado en el alcance. Se propone un mínimo de 16 px para el texto base.
2. RF-4.1 indica que "los usuarios" crean clientes, mientras que RB-4 restringe al editor a solo lectura. Se asume que prevalece RB-4.
3. RF-5.2 no define tamaño máximo de archivo. Se asume 10 MB y validación del tipo real del archivo.
4. RF-5.4 menciona el estado "vence" sin umbral. Se asume 30 días antes de la fecha de término.
5. NFR-USAB exige un "score de usabilidad mínimo aceptable" sin cifra. Se adopta System Usability Scale (SUS) ≥ 70 .
6. No existen requerimientos de consentimiento, derechos del titular ni notificación de brechas, exigibles bajo la Ley 21.719.

3. Plan de pruebas

3.1 Estrategia de pruebas

Enfoque

Adoptamos un enfoque mixto basado en riesgo. Todo lo que se repite en cada cambio (pruebas unitarias, de API, de control de acceso, regresión, carga y análisis estático) se automatiza dentro de la integración continua (CI). Lo que exige criterio humano (usabilidad con adultos mayores, accesibilidad con lector de pantalla, pruebas exploratorias y test de penetración) se ejecuta de forma manual.

El análisis estático de código (SAST) y de dependencias corre desde el primer commit, siguiendo el principio de *shift-left*: la seguridad se verifica durante el desarrollo y no al final, en línea con la seguridad por diseño que plantea la Ley 21.663.

Etapas

Siguiendo ISO/IEC/IEEE 29119, el proceso se organiza en cinco etapas:

1. **Planificación:** análisis de la ERS, identificación de riesgos, alcance y este plan.
2. **Diseño:** casos de prueba, datos de prueba y matriz de trazabilidad.
3. **Preparación:** ambiente de aseguramiento de calidad (QA), datos ficticios, herramientas y pipeline.

4. **Ejecución:** unitarias → integración y API → sistema → no funcionales → seguridad → aceptación.
5. **Cierre:** evaluación de criterios de salida e informe de resultados.

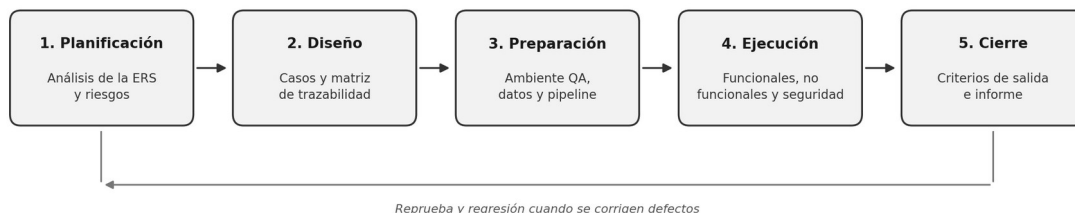


Figura 1. Etapas del proceso de pruebas y su realimentación.

Priorización

La prioridad resulta de cruzar probabilidad e impacto, con mayor peso cuando hay datos personales o bancarios comprometidos.

Prioridad	Riesgo	Requerimientos
P1	Una empresa accede a datos de otra, o un editor logra escribir	RB-2, RB-4, NFR-SEG-4
P1	Inyección SQL, XSS o CSRF	NFR-SEG-5
P1	Sesión válida después del cierre o token manipulado	RF-1.2, NFR-SEG-9
P2	Estado de contrato mal calculado o validaciones que no se aplican	RF-4, RF-5.4
P2	Incumplimiento de los umbrales de rendimiento	NFR-PERF
P3	Barreras de usabilidad o diferencias entre navegadores	NFR-USAB, NFR-COMPAT

Tabla 4. Priorización de riesgos y requerimientos asociados.

Criterios de entrada y de salida

Para iniciar la ejecución se requiere la ERS aprobada con los supuestos de 2.4 confirmados, el build desplegado en QA con TLS, las pruebas unitarias en verde, datos ficticios cargados y autorización escrita para el pentest.

Las pruebas se dan por terminadas cuando el 100 % de los casos P1 está aprobado, no quedan defectos abiertos de severidad crítica o alta, el escaneo dinámico y el pentest no reportan vulnerabilidades críticas ni altas, se cumplen los umbrales de NFR-PERF, el SUS alcanza 70 o más y el Product Owner aprueba el informe de resultados.

La ejecución se suspende si un defecto bloquea más del 30 % de los casos o si aparece una vulnerabilidad que expone datos; se reanuda tras la corrección, con repueba y regresión del módulo afectado.

3.2 Tipos de prueba

Funcionales. Verifican que Atlas haga lo que declara la ERS. Incluyen pruebas unitarias sobre lógica aislada (cálculo del estado del contrato, validación de RUT, política de contraseñas), pruebas de sistema que recorren flujos completos desde la interfaz y regresión automatizada en cada cambio. Las reglas de negocio RB-1 a RB-5 se validan en este nivel.

Integración. Comprueban que frontend, API, base de datos y almacenamiento operen en conjunto. El caso representativo es la carga de un documento: pasa por la API, se guarda en el storage interno, se referencia en PostgreSQL y genera un registro de auditoría (RF-5.2, RF-5.3, RF-6.1). Aquí se ejecuta también la colección Swagger/Postman de endpoints críticos que exige la sección 3.1.2 de la ERS.

Seguridad. Concentran la mayor prioridad. Comprenden SAST y análisis de dependencias, escaneo dinámico de la aplicación (DAST) en QA, pruebas de control de acceso (escritura con rol editor y acceso a recursos de otra empresa mediante manipulación de identificadores, conocida como IDOR), pruebas de sesión y token, verificación de TLS y cifrado en reposo, y pentest manual con checklist ASVS antes de producción.

Rendimiento. Demuestran los umbrales de NFR-PERF: menos de 300 ms en operaciones CRUD simples, carga de la página principal bajo 2 s en red móvil y 200 usuarios concurrentes. Se ejecuta una prueba de carga con la concurrencia esperada y una de estrés para identificar el punto de degradación.

Usabilidad y accesibilidad. Sesiones con cinco adultos mayores, como indica la ERS, midiendo tareas completadas, errores y puntaje SUS, junto con la revisión de conformidad WCAG 2.1 AA: contraste, etiquetas ARIA, navegación por teclado y tamaño de los controles táctiles.

Aceptación. El Product Owner de CreaLab recorre en preproducción los flujos principales con datos ficticios y confirma que el sistema responde a la necesidad del negocio. Es la última actividad antes del cierre.

Compatibilidad. Ejecución de los flujos principales en las dos últimas versiones de Chrome, Firefox, Safari y Edge, y en celular, tablet y escritorio (NFR-COMPAT-1 y 2).

3.3 Criterios de aceptación

Además del criterio propio de cada caso, la aprobación exige cumplir estas condiciones transversales:

- **Funcionales.** La operación se completa y persiste correctamente; las validaciones existen también en el backend, de modo que una petición directa a la API con datos inválidos responde 400 o 422; las eliminaciones son lógicas y requieren confirmación.
- **No funcionales.** p95 bajo 300 ms en CRUD simples y carga de página bajo 2 s; tasa de error inferior al 1 % con 200 usuarios concurrentes; sin incumplimientos críticos de WCAG 2.1 AA.
- **Seguridad y reglas de negocio.** Un recurso no autorizado responde 401 o 403 sin revelar su existencia; ningún mensaje expone contraseñas, tokens, trazas ni sentencias SQL; solo los usuarios de la empresa acceden a sus datos y el editor no crea, edita ni elimina.

Los defectos se clasifican en crítico, alto, medio y bajo. Los dos primeros bloquean la liberación; los demás se aceptan con fecha de corrección comprometida. Cada defecto se registra en Jira con pasos de reproducción, evidencia y requerimiento afectado, y avanza por los estados nuevo, asignado, en corrección, listo para verificar y cerrado. Los defectos de seguridad se gestionan con visibilidad restringida al equipo mientras no estén resueltos.

3.4 Herramientas utilizadas

Herramienta	Uso en el proyecto
Jest y Supertest	Pruebas unitarias y de endpoints en Express
React Testing Library	Pruebas de componentes de la interfaz
Swagger y Postman/Newman	Colección de endpoints críticos exigida por la ERS, ejecutable en el pipeline
Playwright	Flujos end-to-end en Chromium, Firefox y WebKit, con emulación móvil
BrowserStack	Verificación en dispositivos reales
k6	Pruebas de carga y estrés con umbrales configurables
Lighthouse	Tiempo de carga en red móvil y auditoría inicial de accesibilidad
axe DevTools y NVDA	Revisión WCAG automatizada y navegación con lector de pantalla
OWASP ZAP y Burp Suite	Escaneo dinámico y pruebas manuales de token, IDOR y CSRF
SonarQube, Semgrep y npm audit	Análisis estático y vulnerabilidades en dependencias
GitHub Actions	Ejecución automática de las suites en cada integración
Jira	Registro y seguimiento de defectos

Tabla 5. Herramientas seleccionadas y su uso en el proyecto.

3.5 Recursos y cronograma

Equipo. Un QA Lead que coordina y aprueba los criterios de salida, dos analistas QA para diseño y ejecución, un ingeniero de automatización a cargo de los scripts, un analista de seguridad para SAST, DAST y pentest, un especialista en experiencia de usuario para las sesiones con usuarios, el equipo de desarrollo para la corrección de defectos y el Product Owner de CreaLab para resolver dudas y aprobar. Las pruebas de usabilidad requieren además cinco participantes adultos mayores.

Recursos técnicos. Node.js 20 LTS, las versiones del stack declaradas en la ERS y PostgreSQL; Chrome, Firefox, Safari y Edge; equipos Windows y macOS, celulares Android e iPhone, y tablets.

Ambientes. Desarrollo para pruebas unitarias, integración continua para la regresión automatizada, QA como réplica de producción para el resto de las pruebas y preproducción para carga final y aceptación. Ningún ambiente utiliza datos reales de clientes.

Semana	Actividades	Hito
1	Análisis de la ERS, riesgos y aprobación del plan	Plan aprobado
2	Casos, datos de prueba, ambiente QA y pipeline	Ambiente operativo
3	Pruebas funcionales, de integración y de API	Casos P1 funcionales aprobados
4	Rendimiento, compatibilidad y sesiones de usabilidad	Informe de carga y SUS
5	Pruebas de seguridad y pentest	Sin hallazgos críticos
6	Reprueba, regresión, aceptación e informe final	Aceptación formal

Tabla 6. Cronograma referencial de seis semanas.

4. Diseño de casos de prueba

Diseñamos nueve casos que cubren los distintos tipos de requerimientos de la ERS: tres funcionales, tres de seguridad y tres no funcionales. Se priorizaron los riesgos P1 de la sección 3.1 y los requerimientos con umbrales medibles. Los demás requerimientos se cubren con las suites y actividades señaladas en el Anexo A.

CP-01 – Inicio de sesión con credenciales válidas

ID	NOMBRE	REQUERIMIENTO
CP-01	Inicio de sesión con credenciales válidas	RF-1.1, NFR-SEG-1, NFR-SEG-2, NFR-SEG-9
DESCRIPCIÓN		
Verificar que un usuario registrado pueda ingresar con su nombre de usuario y contraseña, y que el sistema entregue un token de sesión válido por una conexión segura.		
PRECONDICIONES		
Usuario activo asociado a una empresa. Ambiente QA con certificado TLS.		
PASOS		
1. Abrir la página de login con http:// y revisar que redirija a https://. 2. Ingresar usuario y contraseña válidos y presionar "Ingresar". 3. Revisar la respuesta de POST /api/auth/login. 4. Revisar en la base de datos cómo está guardada la contraseña.		
RESULTADO ESPERADO		
Respuesta HTTP 200 con un JWT y un refresh token. El usuario llega al dashboard de su empresa. La respuesta no incluye datos sensibles.		
CRITERIO DE ACEPTACIÓN		
La conexión es HTTPS. El JWT tiene expiración de 15 minutos o menos. La respuesta tarda menos de 300 ms. La contraseña está guardada como hash bcrypt (prefijo \$2b\$).		
DATOS DE PRUEBA		
Usuario: admin.pyme01 / Contraseña: Atlas#Prueba2026		
TIPO DE PRUEBA		
Funcional (sistema y API)		

CP-02 – Rol editor sin permisos de escritura

ID	NOMBRE	REQUERIMIENTO
CP-02	Rol editor sin permisos de escritura	RF-3.2, RB-4, NFR-SEG-4
DESCRIPCIÓN		

Comprobar que un usuario con rol editor solo pueda ver información, incluso si intenta crear, modificar o eliminar llamando directamente a la API.

PRECONDICIONES

Usuario editor en la empresa A. Existen al menos un cliente y un contrato.

PASOS

1. Iniciar sesión como editor.
2. Revisar que la interfaz no muestre botones de crear, editar ni eliminar.
3. Con el token del editor, enviar POST /api/contratos.
4. Enviar PUT y DELETE sobre un cliente existente.

RESULTADO ESPERADO

Las peticiones de los pasos 3 y 4 responden HTTP 403 y no cambian nada en la base de datos.

CRITERIO DE ACEPTACIÓN

Ninguna operación de escritura funciona con el rol editor. El bloqueo ocurre en el backend y no depende solo de ocultar botones.

DATOS DE PRUEBA

Usuario: editor.pyme01. JSON de contrato válido para el POST.

TIPO DE PRUEBA

Seguridad (control de acceso)

CP-03 – Aislamiento de datos entre empresas

ID	NOMBRE	REQUERIMIENTO
CP-03	Aislamiento de datos entre empresas	RB-2, NFR-SEG-4, NFR-SEG-8
DESCRIPCIÓN		
Confirmar que un administrador de una empresa no pueda ver ni modificar datos de otra empresa cambiando el identificador en la URL o en la petición.		
PRECONDICIONES		
Empresas A y B con clientes cargados. El administrador solo pertenece a la empresa A.		
PASOS		
1. Iniciar sesión como administrador de A. 2. Enviar GET /api/empresas/102/clientes (empresa B). 3. Enviar GET sobre un cliente de B. 4. Enviar PUT sobre un contrato de B.		
RESULTADO ESPERADO		
Todas las peticiones responden 403 o 404 y no se muestra ningún dato de la empresa B.		
CRITERIO DE ACEPTACIÓN		

No se expone ningún dato personal o bancario de B, tanto con IDs correlativos como aleatorios. La evidencia se guarda como respaldo de cumplimiento de la Ley 19.628.

DATOS DE PRUEBA

ID empresa A = 101, ID empresa B = 102, ID cliente de B = 5530

TIPO DE PRUEBA

Seguridad (control de acceso) y cumplimiento normativo

CP-04 – Creación, validación y eliminación lógica de un cliente

ID	NOMBRE	REQUERIMIENTO
CP-04	Creación, validación y eliminación lógica de un cliente	RF-4.1, RF-4.2, RF-4.3, RB-5, NFR-USAB-3
DESCRIPCIÓN		
Validar que el administrador pueda crear, listar y eliminar clientes, que los campos se validen y que la eliminación sea lógica y con confirmación.		
PRECONDICIONES		
Sesión iniciada como administrador.		
PASOS		
1. Crear un cliente con datos válidos. 2. Intentar crear otro con RUT inválido y teléfono con letras. 3. Buscar el cliente creado usando el filtro por nombre. 4. Eliminarlo y cancelar en la confirmación. 5. Eliminarlo de nuevo y confirmar. 6. Revisar el registro en la base de datos.		
RESULTADO ESPERADO		
El cliente válido se guarda y aparece en el listado. Los datos inválidos muestran un mensaje claro en cada campo. Al cancelar no se elimina; al confirmar desaparece del listado pero sigue en la base de datos marcado como eliminado.		
CRITERIO DE ACEPTACIÓN		
La API también rechaza los datos inválidos (HTTP 422). La paginación y el filtro funcionan. La eliminación no borra físicamente el registro.		
DATOS DE PRUEBA		
Válido: Comercial Ñuñoa Ltda., RUT 76.123.456-0, +56 9 8765 4321. Inválido: RUT 12.345.678-X, teléfono 98ab76.		
TIPO DE PRUEBA		
Funcional (sistema)		

CP-05 – Cálculo del estado de un contrato

ID	NOMBRE	REQUERIMIENTO
CP-05	Cálculo del estado de un contrato	RF-5.1, RF-5.4, RB-3
DESCRIPCIÓN		
Verificar que el estado del contrato (activo, por vencer o expirado) se calcule bien a partir de sus fechas, incluyendo los casos límite.		
PRECONDICIONES		
Cliente creado. Umbral de "por vencer" de 30 días (supuesto de la sección 2.4). Fecha del sistema fijada en 16/09/2026.		
PASOS		
1. Crear los contratos A, B, C y D con las fechas indicadas. 2. Revisar el estado en el listado y en el detalle. 3. Intentar asociar un contrato a un segundo cliente.		
RESULTADO ESPERADO		
A queda activo, B por vencer y C expirado. D se rechaza por fechas incoherentes. El paso 3 no se permite.		
CRITERIO DE ACEPTACIÓN		
Todas las combinaciones muestran el estado correcto, incluidos los límites. Un contrato pertenece a un solo cliente.		
DATOS DE PRUEBA		
A: 01/01/2026 al 31/12/2026. B: 01/01/2026 al 16/10/2026. C: 01/01/2026 al 15/09/2026. D: inicio 01/06/2026 y término 01/05/2026.		
TIPO DE PRUEBA		
Funcional (unitaria y sistema, valores límite)		

CP-06 – Protección contra inyección SQL, XSS y CSRF

ID	NOMBRE	REQUERIMIENTO
CP-06	Protección contra inyección SQL, XSS y CSRF	NFR-SEG-5, RF-4.3
DESCRIPCIÓN		
Comprobar que los formularios y endpoints rechacen o neutralicen entradas maliciosas comunes.		
PRECONDICIONES		
Autorización escrita para el pentest. Ambiente QA aislado con OWASP ZAP y Burp Suite configurados.		
PASOS		

1. Ingresar una carga de inyección SQL en el login y en el filtro de clientes.
2. Guardar un cliente con un script en la descripción y abrir su detalle.
3. Enviar una petición de modificación desde otro origen sin token CSRF.
4. Ejecutar un escaneo activo con OWASP ZAP.

RESULTADO ESPERADO

No se obtiene acceso ni se alteran datos. El script se muestra como texto y no se ejecuta. La petición externa es rechazada. Los errores no muestran información técnica.

CRITERIO DE ACEPTACIÓN

OWASP ZAP no reporta vulnerabilidades críticas ni altas. Las consultas son parametrizadas. Existen cabeceras CSP y CORS restrictivas.

DATOS DE PRUEBA

' OR '1'='1' -- ; <script>alert('xss')</script> ;

TIPO DE PRUEBA

Seguridad (escaneo dinámico y pentest manual)

CP-07 – Carga con 200 usuarios concurrentes

ID	NOMBRE	REQUERIMIENTO
CP-07	Carga con 200 usuarios concurrentes	NFR-PERF-1, NFR-PERF-2, NFR-PERF-3, NFR-DIS-1
DESCRIPCIÓN		
Medir tiempos de respuesta y tasa de error con la concurrencia que define la ERS.		
PRECONDICIONES		
Preproducción equivalente a producción, con 20.000 clientes y 50.000 contratos ficticios. Script de k6 revisado.		
PASOS		
1. Subir de 0 a 200 usuarios virtuales en 5 minutos. 2. Mantener 200 usuarios por 20 minutos haciendo login, listados, creación y edición de clientes. 3. Medir la página principal con Lighthouse en perfil móvil. 4. Registrar CPU, memoria y conexiones a la base de datos.		
RESULTADO ESPERADO		
Las operaciones CRUD simples responden con p95 bajo 300 ms, la página principal carga en menos de 2 s y el servicio no se cae.		
CRITERIO DE ACEPTACIÓN		
Tasa de error menor a 1 %. Los umbrales se cumplen en tres ejecuciones seguidas. Se adjuntan los reportes de k6 y Lighthouse.		
DATOS DE PRUEBA		

Script carga_atlas.js con 60 % lecturas y 40 % escrituras.

TIPO DE PRUEBA

No funcional (rendimiento)

CP-08 – Usabilidad y accesibilidad con adultos mayores

ID	NOMBRE	REQUERIMIENTO
CP-08	Usabilidad y accesibilidad con adultos mayores	NFR-USAB-1, NFR-USAB-2, NFR-USAB-3, NFR-USAB-4
DESCRIPCIÓN		
Evaluar si personas mayores completan tareas habituales sin ayuda y si las pantallas principales cumplen WCAG 2.1 AA.		
PRECONDICIONES		
5 participantes de 60 años o más con consentimiento firmado. Datos ficticios. axe DevTools y NVDA instalados.		
PASOS		
1. Pedir a cada participante buscar un cliente y abrir sus contratos. 2. Pedir crear un cliente cometiendo un error y luego corregirlo. 3. Anotar tiempo, errores y veces que pide ayuda. 4. Aplicar el cuestionario SUS. 5. Revisar las pantallas con axe y recorrerlas solo con teclado y NVDA.		
RESULTADO ESPERADO		
Los participantes completan las tareas sin bloqueos, entienden los mensajes de error y siguen el flujo cliente → contratos.		
CRITERIO DE ACEPTACIÓN		
Al menos 80 % de las tareas completadas sin ayuda. SUS de 70 o más. Contraste mínimo 4,5:1 y controles táctiles de 44 × 44 px o más. Sin errores críticos en axe.		
DATOS DE PRUEBA		
Guion de 3 tareas y cuestionario SUS de 10 preguntas.		
TIPO DE PRUEBA		
No funcional (usabilidad y accesibilidad)		

CP-09 – Compatibilidad entre navegadores y dispositivos

ID	NOMBRE	REQUERIMIENTO
CP-09	Compatibilidad entre navegadores y dispositivos	NFR-COMPAT-1, NFR-COMPAT-2
DESCRIPCIÓN		

Verificar que los flujos principales funcionen igual en los navegadores que exige la ERS y que la interfaz se adapte a escritorio, tablet y celular.

PRECONDICIONES

Ambiente QA desplegado con datos ficticios. Suite de Playwright configurada para Chromium, Firefox y WebKit, y cuenta de BrowserStack disponible.

PASOS

1. Ejecutar con Playwright el flujo de login, creación de cliente, creación de contrato y consulta de auditoría en Chromium, Firefox y WebKit.
2. Repetir el flujo en BrowserStack sobre Chrome y Edge en Windows, Safari en macOS y Safari en iOS.
3. Revisar en cada navegador que tablas, formularios y botones no se corten ni se superpongan.
4. Repetir el recorrido en pantallas de 1920, 768 y 375 px de ancho.
5. En celular, comprobar el tamaño de los controles y que no haga falta desplazarse en horizontal.

RESULTADO ESPERADO

Los flujos se completan en todos los navegadores y tamaños de pantalla, y la interfaz se reordena sin elementos cortados o inaccesibles.

CRITERIO DE ACEPTACIÓN

Sin defectos bloqueantes ni críticos en la matriz de navegadores. Las diferencias entre navegadores son solo visuales (bordes o sombras). En móvil los controles miden al menos 44 × 44 px y no se necesita desplazamiento horizontal.

DATOS DE PRUEBA

Mismos datos de CP-04 y CP-05. Matriz: Chrome, Firefox, Safari y Edge en sus dos últimas versiones; iPhone, Galaxy, iPad y notebook 1080p.

TIPO DE PRUEBA

No funcional (compatibilidad)

5. Cobertura y coherencia

5.1 Cobertura de requerimientos

La ERS contiene 42 requerimientos entre funcionales, reglas de negocio y no funcionales. Todos quedan trazados a una prueba: 27 (64 %) cuentan con un caso detallado en el capítulo 4 y los 15 restantes se cubren con una suite automatizada o una actividad planificada, que se documentará como caso en la iteración 2. El detalle requerimiento por requerimiento está en el Anexo A y en el archivo CSV del repositorio.

Grupo	Total	Con caso detallado	Con actividad planificada
Funcionales (RF)	17	7	10
Reglas de negocio (RB)	5	4	1
Seguridad (NFR-SEG)	9	6	3

Grupo	Total	Con caso detallado	Con actividad planificada
Rendimiento (NFR-PERF)	3	3	0
Usabilidad (NFR-USAB)	4	4	0
Disponibilidad (NFR-DIS)	2	1	1
Compatibilidad (NFR-COMPAT)	2	2	0
Total	42	27	15

Tabla 7. Cobertura de requerimientos por grupo.

La proporción es menor en los requerimientos funcionales porque el diseño priorizó el riesgo: los escenarios P1 de la sección 3.1 (acceso entre empresas, permisos del editor e inyección) tienen caso propio, mientras que flujos como el registro o la gestión de usuarios se cubren con la suite end-to-end, que no requiere un caso manual separado.

5.2 Coherencia del plan

Los objetivos declarados en 1.3 tienen respaldo en casos concretos: los permisos del editor se verifican en CP-02, el aislamiento entre empresas en CP-03, la protección de datos en CP-01 y CP-06, el rendimiento en CP-07, la experiencia del adulto mayor en CP-08 y la compatibilidad en CP-09.

Respecto de OWASP Top 10, quedan cubiertas con caso propio las categorías A01 (control de acceso), A02 (fallas criptográficas), A03 (inyección) y A07 (autenticación). A06 (componentes vulnerables) se controla con el análisis de dependencias del pipeline y A09 (registro y monitoreo) con la revisión de logs y de auditoría planificada.

5.3 Brechas para la iteración 2

- Documentar como casos la revocación de sesión (RF-1.2), el enlace compartido de documentos (RF-5.5), el cifrado en reposo (NFR-SEG-3) y la restauración de respaldos (NFR-SEG-7).
- Confirmar con CreaLab los supuestos de la sección 2.4: tamaño máximo de archivo, umbral de vencimiento y puntaje SUS mínimo.
- Proponer requerimientos de consentimiento, derechos del titular y notificación de brechas, exigibles bajo la Ley 21.719 y ausentes en la ERS.

6. Conclusión

Atlas maneja datos personales y bancarios de clientes de distintas empresas en una misma plataforma. Por eso el plan pone el mayor esfuerzo en el control de acceso y la protección de

datos, sin dejar de lado el rendimiento ni la usabilidad para adultos mayores, que la ERS marca como prioridades.

El enfoque mixto permite automatizar lo que se repite en cada versión y reservar el trabajo manual para lo que necesita criterio humano. La matriz de trazabilidad deja cada requerimiento conectado a una prueba y a una norma, lo que sirve tanto para encontrar defectos como para demostrar cumplimiento frente a la Ley 19.628 y la Ley 21.719.

Durante el análisis también encontramos vacíos en la propia ERS: umbrales sin definir, una contradicción en los permisos del editor y la ausencia de requerimientos de consentimiento y aviso de brechas. Los dejamos documentados para trabajarlos en la siguiente iteración del caso semestral.

Referencias

- Biblioteca del Congreso Nacional de Chile. (1970). *Ley 17.336 sobre propiedad intelectual*.
- Biblioteca del Congreso Nacional de Chile. (1999). *Ley 19.628 sobre protección de la vida privada*.
- Biblioteca del Congreso Nacional de Chile. (2022). *Ley 21.459 que establece normas sobre delitos informáticos*.
- Biblioteca del Congreso Nacional de Chile. (2024). *Ley 21.663 marco de ciberseguridad*.
- Biblioteca del Congreso Nacional de Chile. (2024). *Ley 21.719 que regula la protección y el tratamiento de los datos personales*.
- CreaLab SpA. (2026). *Especificación de requerimientos de software: Sistema de Gestión Atlas (v1.1)*.
- ISO/IEC. (2023). *ISO/IEC 25010: Systems and software quality requirements and evaluation (SQuaRE) – Product quality model*.
- ISO/IEC. (2022). *ISO/IEC 27001: Information security management systems – Requirements*.
- ISO/IEC/IEEE. (2022). *ISO/IEC/IEEE 29119: Software and systems engineering – Software testing*.
- OWASP Foundation. (2021). *OWASP Top 10*.
- OWASP Foundation. (2021). *Application Security Verification Standard 4.0.3*.
- W3C. (2018). *Web Content Accessibility Guidelines (WCAG) 2.1*.

Anexo A. Matriz de trazabilidad

Relación entre cada requerimiento de la Especificación de Requerimientos de Software (ERS), el caso de prueba que lo verifica y la norma que respalda el control. Los requerimientos sin caso detallado se cubren con la suite o actividad indicada. La misma matriz está disponible en formato CSV en la carpeta anexos del repositorio.

Requerimiento	Descripción	Caso o actividad	Tipo de prueba	Norma o estándar
RF-1.1	Autenticación con usuario y contraseña	CP-01	Funcional	OWASP A07
RF-1.2	Cierre de sesión y revocación de tokens	Suite de API (sesión)	Seguridad	OWASP A07
RF-2.1	Registro de usuario	Suite end-to-end	Funcional	Ley 21.719
RF-2.2	Creación de empresa	Suite end-to-end	Funcional	ISO/IEC 25010
RF-2.3	Primer usuario como administrador	Suite end-to-end	Funcional	ISO/IEC 27001
RF-3.1	Invitar o crear usuarios con rol	Suite de API	Funcional	ISO/IEC 27001
RF-3.2	Editor solo visualiza	CP-02	Seguridad	OWASP A01
RF-3.3	Modificar o eliminar usuarios	Suite de API	Funcional	ISO/IEC 27001
RF-4.1	Crear clientes	CP-04	Funcional	ISO/IEC 25010
RF-4.2	Editar, eliminar y listar clientes	CP-04	Funcional	Ley 19.628
RF-4.3	Validación de campos	CP-04, CP-06	Funcional y seguridad	OWASP A03
RF-5.1	Crear contratos por cliente	CP-05	Funcional	ISO/IEC 25010
RF-5.2	Adjuntar documentos	Suite de integración	Integración	OWASP A04
RF-5.3	Documentos en storage interno	Suite de integración	Integración	ISO/IEC 27001
RF-5.4	Estado del contrato por fechas	CP-05	Funcional	ISO/IEC 25010
RF-5.5	Enlace para compartir documento	Prueba de seguridad planificada	Seguridad	OWASP A01, Ley 19.628
RF-6.1	Auditoría de acciones críticas	Suite de integración	Funcional	OWASP A09, Ley 21.719

Requerimiento	Descripción	Caso o actividad	Tipo de prueba	Norma o estándar
RB-1	Correo principal único	Suite end-to-end	Regla de negocio	Integridad de datos
RB-2	Acceso solo a usuarios de la empresa	CP-03	Seguridad	Ley 19.628, OWASP A01
RB-3	Contrato asociado a un cliente	CP-05	Regla de negocio	Integridad de datos
RB-4	Editor solo lectura	CP-02	Seguridad	OWASP A01
RB-5	Administrador con acceso completo	CP-04	Funcional	Mínimo privilegio
NFR-SEG-1	TLS obligatorio	CP-01	Seguridad	OWASP A02
NFR-SEG-2	Contraseñas con bcrypt	CP-01	Seguridad	OWASP A02
NFR-SEG-3	Cifrado de datos sensibles en reposo	Revisión de base de datos en QA	Seguridad	Ley 19.628, ISO/IEC 27001
NFR-SEG-4	Control de acceso por rol en backend	CP-02, CP-03	Seguridad	OWASP A01
NFR-SEG-5	Protección contra CSRF, XSS y SQLi	CP-06	Seguridad	OWASP A03
NFR-SEG-6	Gestión segura de logs	Revisión de logs	Seguridad	OWASP A09
NFR-SEG-7	Respaldo y recuperación	Prueba de restauración	Confiabilidad	ISO/IEC 27001
NFR-SEG-8	Cumplimiento de protección de datos	CP-03	Cumplimiento	Ley 19.628, Ley 21.719
NFR-SEG-9	Sesión con JWT	CP-01	Seguridad	OWASP A07
NFR-PERF-1	CRUD bajo 300 ms	CP-07	Rendimiento	ISO/IEC 25010
NFR-PERF-2	Página principal bajo 2 s en móvil	CP-07	Rendimiento	ISO/IEC 25010
NFR-PERF-3	200 usuarios concurrentes	CP-07	Rendimiento	ISO/IEC 25010
NFR-USAB-1	Tipografía, contraste y controles grandes	CP-08	Usabilidad	WCAG 2.1 AA
NFR-USAB-2	Flujos claros de registro	CP-08	Usabilidad	ISO/IEC 25010
NFR-USAB-3	Ayuda y errores amigables	CP-04, CP-08	Usabilidad	WCAG 2.1 AA
NFR-USAB-4	Flujo cliente → contratos	CP-08	Usabilidad	ISO/IEC 25010
NFR-DIS-1	Disponibilidad de 99,5 %	CP-07 y monitoreo	Confiabilidad	ISO/IEC 25010

Requerimiento	Descripción	Caso o actividad	Tipo de prueba	Norma o estándar
NFR-DIS-2	Mantenimiento y migración segura	Prueba de migración	Mantenibilidad	ISO/IEC 27001
NFR-COMPAT-1	Navegadores modernos	CP-09	Compatibilidad	ISO/IEC 25010
NFR-COMPAT-2	Responsivo en móvil y tablet	CP-09	Compatibilidad	ISO/IEC 25010

Tabla A.1. Trazabilidad de los 42 requerimientos de la ERS.